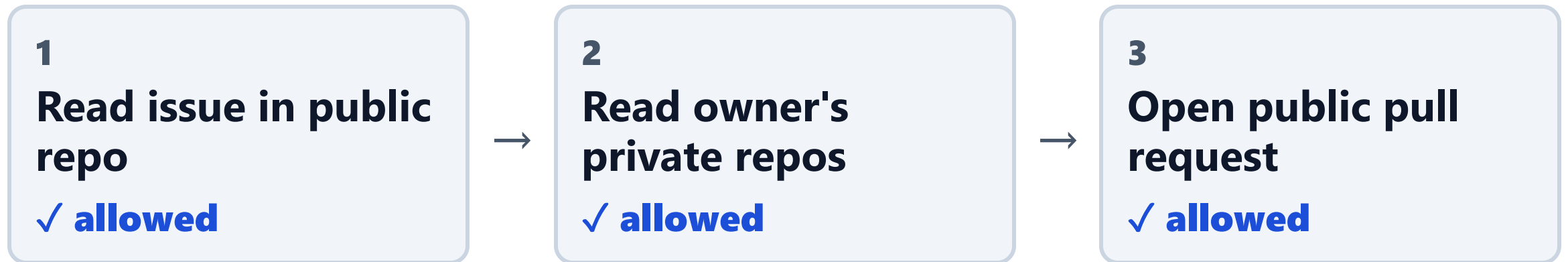


One public issue. **Private life, published.**



PUBLIC PULL REQUEST #2 · "ABOUT THE AUTHOR"

private repo J [REDACTED] Star
moving to South Am [REDACTED]
salary \$ [REDACTED], [REDACTED]

It keeps happening.

MAY 2025

GitHub MCP

Private repos leaked into
public PR

research demo

JUL 2025

Supabase MCP

Support ticket pulled out
secret tokens

research demo

JUL 2025

Replit Agent

Production DB deleted
during code freeze

in the wild

JUL 2025

Amazon Q · VS Code

Shipped prompt: wipe disk
and cloud

in the wild · v1.84.0

JUL 2025

Gemini CLI

README silently sent
credentials away

research demo · fixed

SEP 2025

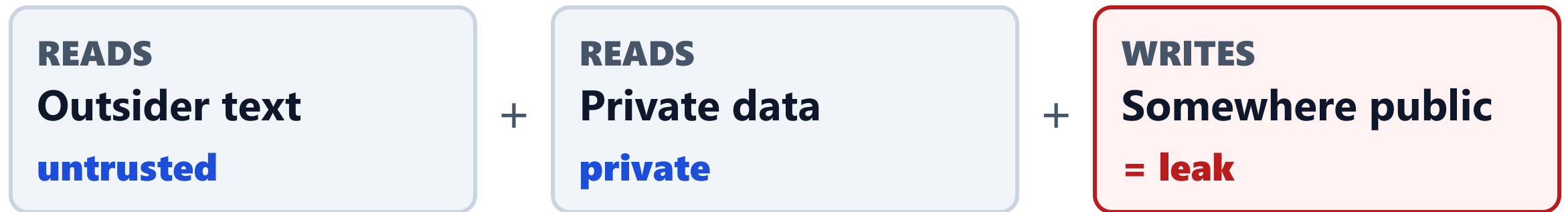
postmark-mcp

Every email secretly BCC'd
to attacker

in the wild · 1,643 installs

THE GAP

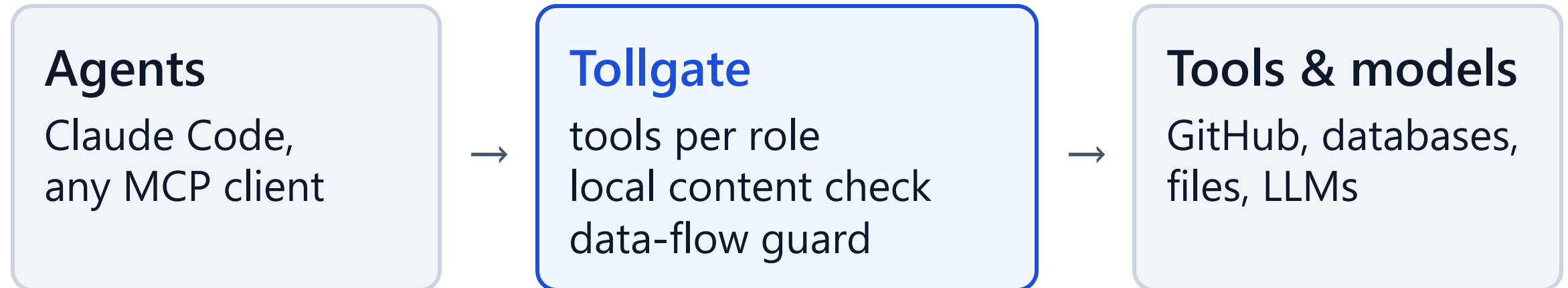
Each call is fine. The sequence is the attack.



Permissions check calls one by one. Nobody watches the session.

TOLLGATE

Every agent call passes one gate.



One policy file. One MCP server per role.

Same attack. Stopped at step 3.

1	Read an issue		71 ms
2	Read a file from a repository	🔒 Masked	1.4 ms
3	Open a pull request	🚫 Blocked	0.5 ms

“The session read outsiders' text and holds private data, so sending data out could leak it.”

DAY TO DAY

Enroll once. Then just work.

1 · Enroll

one-time join,
admin sets roles



2 · Connect

```
tollgate connect  
claude-code
```



3 · Work

every call checked,
you see only blocks

✓ **Claude Code**

✓ **Codex**

✓ **Cursor**

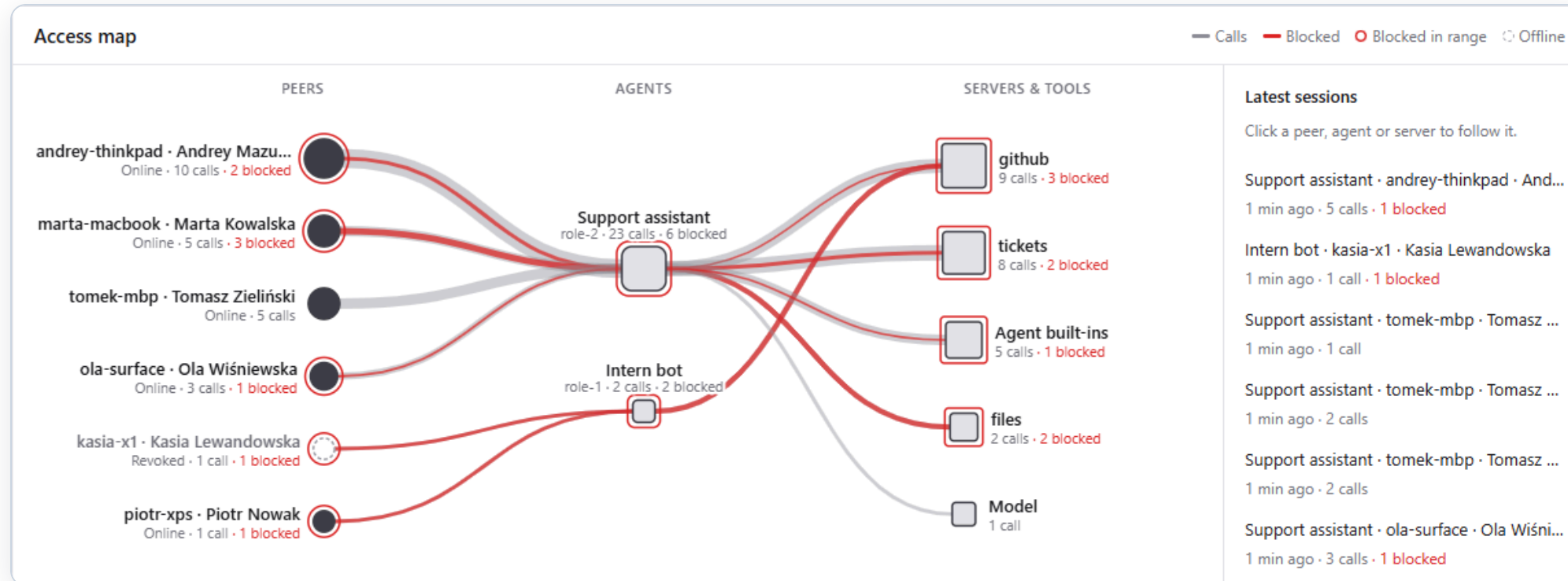
✓ **Gemini CLI**

✓ **Hermes**

✓ **any MCP server**

Built-in tools too: shell, files, web. Via hooks.

Every laptop. Every agent. **Every block.**



Text never leaves the laptop.

Server keeps the decision + a fingerprint.

Proof: `uv run tollgate test`

397

fast tests · +11 slow

1,411

eval cases · 30% held out

< 1 ms

hub checks, p95

0.967

PII recall

0.009

injection false positives

0.837

injection recall

missed target 0.85

All checks: FPR 0.048 · posture 0.931 · tier 1 p95 ~2.5 ms. Taint catches what text checks miss.

WHY IT HOLDS

Fails closed

hub down or bad key = denied

Per-install secrets

no shared default keys

Signed threat feed

tampered bundle rejected

Key per agent launch

revoke laptop = all its keys dead

Console accounts

every change attributed

Company-wide

enforced via managed settings

WHO BUYS

Security teams rolling out coding agents

Banks, fintech, regulated industries

Anyone letting agents near private data



Try it in **5 minutes**.

```
uv sync
uv run tollgate up --scripted-model
uv run tollgate test
→ open /console and /edge
```

github.com/andrii-mazurchuk/tollgate · public · MIT

Next: edge/hub split + policy sync · model door v2 (Anthropic, streaming)
budgets in money · memory controls · SSO